



Executive Summary



Executive Summary

Based on Xibalba's current digital infrastructure, there are threat actors that are constantly looking for ways to penetrate the system, whether it's for personal agenda, blackmailing, or even time-passing. These threat Actors can do this via loopholes that exist in a company's infrastructure. Usually, these loopholes are found in various parts of a company's platforms. Those platforms are called the Attack Surface. Attack surfaces are often the pathways that threat actors choose to exploit and cause problems within the system. Upon reviewing Xibalba Interactive's digital infrastructure, we found that it is outdated and also gives threat actors three attack surfaces that they can use to exploit the system. Those three attack surfaces are as follows: Developer Environments, Billing Staff & Social Engineering & In-game user account access. Usually, those who have a personal agenda or are looking to get something out of their exploitation, such as financial benefits, are called cybercriminals, and those who exploit just for fun or time passing are called Script Kiddies. The attack surfaces we found that could be exploited surround these two threat actors. The priority on taking detective and preventive solutions against cybercriminals is high, whereas for script kiddies it's medium but still important.

The Solution Roadmap that we created will counter any move taken by the threat actors against Xibalba Interactive. The solution roadmap includes continuous monitoring by honeypots. The solution also includes a detection and a mitigation solution. All of these solutions fall into place in line with one another, performing their tasks one after another.

The honeypot is always there to act as a bait for the threat actors. The moment the threat actors fall victim to our honeypot strategy, Xibalba will get informed right away. For example, Honeycreds are used to notify when there are numerous unsuccessful login attempts with stolen credentials. So, in case of any compromise to our user accounts, HoneyCred is there to save the day.

The detective solutions are there to detect anything unusual or any suspicious activity running against the system. For example, Active Directory management. This detective system logs all the major events occurring in the system. So, from login activity to password changes to even granting low privileged account access to classified files/folders.

Preventive measures are when honeypots and detection measures are not enough to stop the threat actor. For example, in the case of any data breaches, the mitigation: Data loss prevention acts against any and all data leaks.





Threat Model for Xibalba Interactive



Threat Actors



Threat Actors

1. Cybercriminals

The Threat Actor is relevant to this threat model because they are constantly seeking financial gain through theft or fraud, such as card skimming, data exfiltration, or malware infections.

1. SCENARIO:

2. **Malware-infested link through phishing email causing financial damage :**

Sending a phishing email with malware disguised as an insider, such as an employee or customer.

Waiting for the user to click on the link, then the process injection begins after all the information is in the hands of the TA, which they later transfer to their platform

(T1598.003: Phishing for Information, T1204: User Execution, T1554: Compromise Host Software Binary, T1055: Process Injection, T1567: Exfiltration Over Web Service)

2. Cybercriminals

These types of threat actors are relevant because they think about getting to the bottom of their target. Such as stealing valuable data and selling it on the dark web. They can do this by phishing emails, Drive-by downloads, or Ransomware to lock and extort data.

3. SCENARIO:

4. **From manipulating accounts to hijacking internal resources:**

Manipulating an Admin's account and exploiting it to the fullest extent. Using the Admin's account to share all the information through data manipulation and sharing it on the black market.

(T1098: Account Manipulation, T1567: Exfiltration Over Web Service, T1565: Data Manipulation, T1496: Resource Hijacking)

3. Script Kiddies

Script kiddies are a real threat in this case because they use easy tools to hack into in-game chats just to show off. Their goal is to gain attention in online forums or gaming communities. They might run DDoS attacks to cause chaos, brute-force weak passwords, or use basic malware to steal chat data. Even though they're not highly skilled, they can still leak private info or embarrass players. That's why it's important to take them seriously and have strong basic security in place.

5. SCENARIO:

6. **Gaining notoriety in online forums or communities:** Using their own account to implement internal spearfishing and putting spyware which they later hide and transfer information as the spyware gets them. Thus, causing corruption. (T1586: Compromise Accounts, T1651: Cloud Administration Command, T1534: Internal Spearphishing, T1665: Hide Infrastructure, T1011: Exfiltration Over Web Service, T1495: Firmware Corruption)



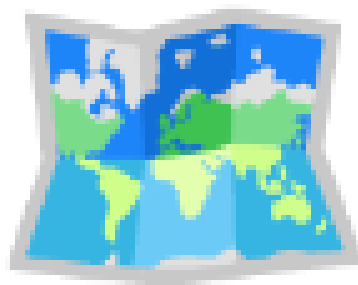
Attack Surface

[illegible]

[illegible]



Solution Roadmap



Solution Roadmap for Xibalba Interactive

Honey strategies



Honey strategy Solutions:

Honey strategy Solutions:	1
Honeymail to detect phishing email:	2
STAKEHOLDERS:	2
Executives:	2
IT Team:	2
Legal:	2
GOALS:	2
Create a honeymail in 1 month:	2
Honeyfile, honeytoken, honeydata to detect suspicious activity:	3
STAKEHOLDERS:	3
Executives:	3
IT Team:	3
Legal:	3
GOALS:	3
Create a honeyfile or honeydata within 2 months:	3
Honeycreds to spot unusual login attempts:	4
STAKEHOLDERS:	4
Executives:	4
IT Team:	4
Legal:	4
GOALS:	4
Create honeycreds for all company-owned devices, uniquely for all individual devices within 2 months:	4

Honeypot Solution #1

Honeymail to detect phishing email

Difficulty: 2 (Medium) ▾

Priority: 3 (High) ▾

A legitimate but unused email address from the company's domain (matched with an enticing fake persona) is listed in the company's public-facing infrastructure. Used to identify targeted phishing campaigns.

Addresses attack vector(s):

- T1598.003: Phishing for Information

Protects key asset(s):

- Payment information of users for billing (paid subscriptions).

STAKEHOLDERS

Executives

IT Team

Legal

Executives should take this as a critical matter because it acts as a preventive measure for any phishing attack. Every interaction between the honeymail and the phishing attack can also be well-documented.

IT teams should support this because it strengthens email defenses, enables proactive phishing detection, and improves response time.

Legal/compliance teams should care because Honeymail can help avoid regulatory penalties by demonstrating phishing monitoring and quick response capabilities.

GOALS

Name

Description

Deadline

Create a honeymail in 1 month

Create honeymail from the company's domain to act as a bait to catch any TA trying a phishing attack.

1 Month.



Honeytoken Solution #2

Honeyfile, honeytoken, honeydata to detect suspicious activity

Difficulty: 3 (Hard) ▾

Priority: 3 (High) ▾

Enticing files or data that alert as soon as opened/accessed/viewed

Addresses attack vector(s):

- T1586: Compromise Accounts

Protects key asset(s):

- In-game private chat system

STAKEHOLDERS

Executives

Executives benefit by gaining stealth breach detection and reducing costly incident impact, especially from insider threats.

IT Team

IT teams should support this for its low cost, high-detection value, and real-time alerting on unauthorized access attempts.

Legal

Legal teams benefit from demonstrable controls that satisfy compliance requirements and reduce legal liability in the event of a breach.

GOALS

Name

Description

Deadline

Create a honeyfile or honeydata within 2 months

Create a honeyfile, honeydata to track suspicious activity among sensitive data on all company-owned devices. This will help identify and notify of any file accessed by a TA.

2 Months



Honeypot Solution #3

Honeycreds to spot unusual login attempts

Difficulty: 3 (Hard) ▾

Priority: 3 (High) ▾

Enticing credentials that alert as soon as a login attempt occurs

Addresses attack vector(s):

- T1098: Account Manipulation

Protects key asset(s):

- Intellectual property (IP): proprietary game source code.

STAKEHOLDERS

Executives

IT Team

Legal

Executives should prioritize this for its fast detection capabilities and ability to limit damage from stolen credentials.

IT teams benefit from faster incident detection, clearer visibility, and improved credential security posture.

Legal/compliance teams benefit from reduced regulatory risk and improved documentation of access control efforts

GOALS

Name

Description

Deadline

Create honeycreds for all company-owned devices, uniquely for all individual devices within 2 months

Create honeycreds to be notified when somebody is trying to access a device that is not assigned to them

2 Months.



Data sources



Data Sources:

 Data Sources:	1
DS0015: DS0021: Persona (Social Media).....	1
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
DS0029: Network Traffic (Network Traffic Content).....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	3
Increase cybersecurity awareness.....	3
T1098: Active Directory (Active Directory Object Modification).....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
Make security a priority.....	3



Data Source Solution #1

**DS0015: DS0021: Persona
(Social Media)**

Difficulty: 1 (Easy) ▾

Priority: 2 (Medium) ▾

Consider monitoring social media activity related to your organization. Suspicious activity may include personas claiming to work for your organization or recently modified accounts making numerous connection requests to accounts affiliated with your organization. Much of this activity will take place outside the visibility of the target organization, making detection of this behavior difficult. Detection efforts may be focused on related stages of the adversary lifecycle, such as during Initial Access (ex: Phishing).

Addresses attack vector(s):

- T1586: Compromise Accounts

STAKEHOLDERS		
Executives	IT Team	Legal
The reason why this is a critical issue and why it should be brought to attention is to protect the reputation of the organization by reducing the risk of disinformation against the org and any scams that targets organizations community	This should be brought to attention because it only requires 1 or 2 people to successfully monitor social media and keep track of all updates. While it increases the number of tasks, it is a good investment for the company to protect its reputation. That way, it will be easier and by splitting the task between 2 people will reduce the workload.	The legal and compliance team should care because impersonation poses legal risks to the company, including lawsuits, compliance violations, and financial penalties. By supporting this solution, the team can ensure that intellectual property and brand identity are protected while also demonstrating due diligence in mitigating digital threats.
GOALS		
Name	Description	Deadline
ADD GOAL #1 NAME HERE	Make monitoring social media a priority every once a week.	3 months

 Data Source Solution #2		
DS0029: Network Traffic (Network Traffic Content)	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Monitor and analyze traffic patterns and packet inspection associated to protocol(s) that do not follow the expected protocol standards and traffic flows (e.g extraneous packets that do not belong to established flows, gratuitous or anomalous traffic patterns, anomalous syntax, or structure). Consider correlation with process monitoring and command line to detect anomalous processes execution and command line arguments associated to traffic patterns (e.g. monitor anomalies in use of files that do not normally initiate connections for respective protocol(s)).		
Addresses attack vector(s):	- T1598.003: Phishing for Information	
STAKEHOLDERS		
Executives	IT Team	Legal
This is an important matter to this stakeholder because it can help protect us from numerous phishing attack attempts that happen everyday in our daily life. Attacks like this occurs because of the greed for money of the threat actors. if	This should be an important matter to the IT teams since it will help make their work easier for the team and also save plenty of time and risk in the long run.	The reason why this is a critical issue to the legal team is because it regulates with the compliance and can also provide documentation during an audit.

these attack can be stopped or identified, it can save us tons of money in the long run.		
GOALS		
Name	Description	Deadline
Increase cybersecurity awareness	Develop a course that educates on cybersecurity awareness among the employees and customers within 2 months	2 months.

 Data Source Solution #3		
T1098: Active Directory (Active Directory Object Modification)	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Monitor events for changes to account objects and/or permissions on systems and the domain, such as event IDs 4738, 4728, and 4670. Monitor for modification of accounts in correlation with other suspicious activity. Changes may occur at unusual times or from unusual systems. Especially flag events where the subject and target accounts differ, or that include additional flags such as changing a password without knowledge of the old password. Monitor for unusual permissions changes that may indicate excessively broad permissions being granted to compromised accounts.		
Addresses attack vector(s):	- T1098: Account Manipulation	
STAKEHOLDERS		
Executives	IT Team	Legal
Executives should care because a weak identity verification process can result in financial, operational, and reputational harm. Implementing this solution enhances security posture while showing strong leadership in cybersecurity governance.	IT teams should care because these enhancements prevent exploitation of directory weaknesses, reduce cleanup time post-breach, and improve overall system integrity.	Legal and compliance teams should care because implementing stronger verification processes reduces legal liabilities and ensures regulatory compliance across operations.
GOALS		
Name	Description	Deadline
Make security a priority	Implement Two-step verification	1 month

	process for administrative access within 1 month	
--	---	--



Mitigations



Preventive Mitigations:

 Preventive Mitigations:	1
M1026: Privileged Account Management.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
Implementing the use of individual laptops for each employee.....	2
M1057: Data loss prevention.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
Upload SIEM.....	3



Preventive Solution #1

M1026: Privileged Account Management

Difficulty: 1 (Easy) ▾

Priority: 3 (High) ▾

Privileged Account Management focuses on implementing policies, controls, and tools to securely manage privileged accounts (e.g., SYSTEM, root, or administrative accounts).

Addresses attack vector(s):

- T1098: Account Manipulation, T1651: Cloud Administration Command

STAKEHOLDERS

Executives

Executives should care because improper use of admin privileges can lead to costly breaches and regulatory fines. Implementing PAM strengthens security posture and shows a commitment to governance and accountability.

IT Team

IT teams should care because this approach improves operational control, lowers risk, and simplifies endpoint security management.

Legal

Legal teams should support this solution to meet access control regulations, limit liability, and ensure forensic traceability in case of a breach.

GOALS

Name

Description

Deadline

Implementing the use of individual laptops for each employees.

Provide each employee with a personal laptop within 3 months, which they will use to access official work

3 Months



Preventive Solution #2

M1057: Data loss prevention

Difficulty: 2 (Medium) ▾

Priority: 3 (High) ▾

Data Loss Prevention (DLP) involves implementing strategies and technologies to identify, categorize, monitor, and control the movement of sensitive data within an organization. This includes protecting data formats indicative of Personally Identifiable Information (PII), intellectual property, or financial data from unauthorized access, transmission, or exfiltration. DLP solutions integrate with network, endpoint, and cloud platforms to enforce security policies and prevent accidental or malicious data leaks.

Addresses attack vector(s):

- T1567: Exfiltration Over Web Service, T1011: Exfiltration Over Web Service

STAKEHOLDERS

Executives

Executives should care because data loss leads to revenue damage, reputational harm, and legal consequences. SIEM ensures data is tracked and protected across all digital assets.

IT Team

IT teams should support this for improved detection, easier root cause analysis, and a more robust security monitoring framework.

Legal

Legal/compliance teams should prioritize this solution to ensure regulatory compliance, enable rapid reporting, and limit liability during audits or investigations.

GOALS

Name

Description

Deadline

Upload SIEM

Upload SIEM on every company-owned device within 3 months

3 Months